PQCrypt

A Post-Quantum Encryption Envelope

with optional X25519 hybrid (suite `0x06`)

Bahram Samani

`pqtoolkit` monorepo maintainer

Whitepaper, Version 1.3

Released 2026-05-21

Build date: June 8, 2026 **Build time:** 17:36 UTC

Source: `pqcrypt/latex/main.tex`

Spec version: v1.3 **Wire variant:** `0x04` **Suites:** `0x01`, `0x02`, `0x06`

This document is the canonical reference for PQCrypt v1.x. It supersedes the v1 (2026-05-20) and v1.2 (2026-05-21 Python-only hybrid) drafts. See section 14, Appendix F, for the v1.0–v1.3 release timeline.

Contents

TL;DR **3**

1 Threat Model **4**

2 Wire Format (Normative) **4**

3 Algorithm Suites **5**

4 ML-KEM-1024 Binding **6**
4.1 Tight QROM proof . . . 6
4.2 Implementation sources (v1.x, as shipped) . . . 7
4.3 The "Kyber" naming ban . . . 7

5 Hybrid Suite `0x06` (Optional) **7**
5.1 Construction . . . 8
5.2 Sizes . . . 8
5.3 Security argument . . . 8
5.4 Cost . . . 8
5.5 Constant-time and supply-chain posture . . . 9

6 AEAD and Commitment **9**
6.1 Why a separate commitment tag . . . 9
6.2 The UtC construction (Bellare & Hoang 2022) . . . 9
6.3 Verification . . . 9
6.4 Why UtC over CTX, GCM-SST, or compactly-committing schemes . . . 10
6.5 Commitment vs content binding . . . 10

7 Key Derivation and Deterministic Nonce **10**
7.1 Key schedule . . . 10
7.2 Salt binding . . . 10
7.3 Why deterministic nonce . . . 11
7.4 Multi-user / multi-key bounds . . . 11

8 The PQID-as-AD Canonical Pattern **11**

9 Failure Modes **12**
9.1 One error class for every authentication-class failure . . . 12
9.2 Constant-time discipline . . . 12
9.3 Timing-histogram regression . . . 13
9.4 Implicit-reject semantics . . . 13

10 Side Channels **13**
10.1 Known attacks 2024–2026 . . . 13
10.2 What v1 mitigates . . . 13
10.3 What v1 does *not* mitigate . . . 14

10.4 Forward path 14

11 Plugin Protocol **14**
11.1 Why a plugin protocol in v1 14
11.2 Wire format 15
11.3 Reference plugin: `pqcrypt-plugin-file` 15
11.4 What the protocol does *not* cover 15

12 Conformance **16**
12.1 KAT vector files 16
12.2 Cross-language runner 16
12.3 Hybrid suite `0x06` skip discipline 16
12.4 Local invocation 17
12.5 Branch-protection gate 17
12.6 Vector generation 17

13 Comparison with Existing Formats **17**
13.1 Envelope formats 19
13.2 KEM cost (Zen 4, cycles; sizes in bytes) 20
13.3 AEAD throughput (1 MiB, single thread, GB/s) 20
13.4 Reference benchmarks (Apple M4 Max, ops/sec, v1.3) 20
13.5 Deployment scale (Nov 2026) 21

14 Appendices **21**

TL;DR

PQCrypt is a 16-byte-header, variable-body **post-quantum encryption envelope** format with byte-identical polyglot reference implementations under the `pqtoolkit` monorepo. It joins PQID (41-byte identifier, variant bytes `0x01`/`0x02`) and PQHash (73-byte content hash, variant byte `0x03`) as the third project in the family, owning variant byte `0x04`.

v1.x ships three suites, allocated at the `SUITE` byte (header offset 7):

- **Suite `0x01` (mandatory, pure PQ). ML-KEM-1024** (fip, 2024) + **AES-256-GCM** + a **32-byte UtC commitment tag** (Bellare and Hoang, 2022) + **HKDF-SHA3-256**. The v1 baseline.
- **Suite `0x02` (optional, pure PQ).** Substitutes ChaCha20-Poly1305 for callers without AES hardware. Same UtC commitment.
- **Suite `0x06` (optional, hybrid; v1.2).** Adds **X25519** (Langley et al., 2016) alongside ML-KEM-1024 with an X-Wing–style SHAKE-256 combiner (Connolly et al., 2025). Opt-in defense-in-depth for callers who want a classical safety net against a Module-LWE structural break.

Suites `0x01`/`0x02` carry the unambiguous post-quantum confidentiality promise: the residual Module-LWE-break risk (sections 1 and 14) is the deliberate cost. Suite `0x06` is the *opt-in* alternative that mitigates that residual risk; it is a separate suite-byte allocation, never an in-place modification of `0x01`/`0x02`. The wire is unambiguous about which promise a given envelope makes.

At a glance

- **Three suites, three explicit promises.** No agility within a suite, no negotiation, no downgrade. A suite byte *is* a version.
- **Key-committing.** Every envelope carries a 32-byte UtC commitment tag (HMAC-SHA3-256) — closes the multi-recipient confusion class that age v1.x still has open.
- **Deterministic AEAD nonce** derived from a per-envelope-fresh session key. No CSPRNG dependency on the encrypt path beyond ML-KEM's internal `Encaps` randomness (and the X25519 ephemeral keygen in hybrid).
- **Single `DecryptionError`** for every authentication-class failure. No distinguishing oracle. Structural errors (truncation, unknown variant/suite, suite/key mismatch) are distinguishable safely.
- **Binds PQID as AD** by convention. Envelope rebinding fails closed (section 8).
- **Plugin protocol ships in v1.** Key-on-disk lives in the plugin, not the core spec. Reference `pqcrypt-plugin-file` uses `.pqck-key-v1.1` (Argon2id (rfc, 2021) + AES-256-GCM key wrap with embedded public key).
- **Inherits monorepo discipline.** Spec-first LaTeX (this document); Python is the readable reference; C pins the canonical ABI; cross-language KAT vectors gate CI.
- **Polyglot status (v1.3, 2026-05-21):** Python, C, Go, Rust ship suites `0x01`/`0x02`; Python, Rust, Go ship hybrid `0x06`; C++, TypeScript, Java, CPython ext v1.1 wrappers ship suites `0x01`/`0x02` and add hybrid in v1.4 (section 12, Appendix F).

1 Threat Model

The attacker is computationally bounded by the IND-CCA2 security of ML-KEM-1024 (fip, 2024; Hofheinz et al., 2017) and the confidentiality and integrity of the symmetric AEAD (AES-256-GCM under its standard assumptions, augmented with the UtC commitment tag (Bellare and Hoang, 2022)). They see every byte of every envelope, may control delivery (replay, reorder, drop), may have a decryption oracle for *other* ciphertexts under the same recipient key (IND-CCA2 required), and may flip any header byte or substitute associated data (the AEAD's AD path authenticates both).

The attacker **cannot** compromise the recipient's long-term ML-KEM-1024 private key (and, for hybrid suite `0x06`, the X25519 long-term scalar): that is the plugin protocol's responsibility (section 11). The attacker may attempt *multi-recipient/AEAD-key confusion* (Grubbs et al., 2017; Albertini et al., 2020; Len et al., 2021); the 32-byte UtC commitment tag closes this class on every suite, including hybrid.

The attacker may attempt *side-channel attacks* against ML-KEM: KyberSlash 1/2 timing leaks (Bernstein et al., 2024), PQShield power-side-channel disclosures (PQShield, 2024), and SPA-CCA (Guo et al., 2024). They may attempt timing or power side-channels against the X25519 half of suite `0x06`. PQCrypt mitigates software-timing leakage by vendoring constant-time ML-KEM-1024 and X25519 implementations per language (sections 4 and 5) and documents an explicit "constant-time $\neq$ constant-power" disclaimer (section 10). Physical-access attacks (power, EM, frequency-scaling (Wang et al., 2022), prefetcher (Chen et al., 2024)) remain out of v1.x scope.

The attacker may attempt a *suite-confusion* attack: present an envelope with a suite byte that does not match the recipient's key, or re-tag a hybrid envelope as non-hybrid (or vice versa). PQCrypt rejects this structurally at the API boundary (section 9): `encrypt` rejects a recipient key whose suite does not match the requested suite; `decrypt` rejects an envelope whose header suite does not match the private key's suite. Both are `BadKey`-class structural errors, distinguishable safely because they do not depend on secret-correlated bytes.

Residual risk and the v1.2 hybrid escape valve

PQCrypt's **core promise** (suites `0x01`/`0x02`) is post-quantum-only by deliberate scope. If ML-KEM-1024 is later structurally broken (a sub-exponential Module-LWE attack), every `0x01`/`0x02` envelope loses confidentiality with no classical fallback. This 30–50 year risk is accepted in exchange for an unambiguous PQ-only promise; the mitigation path is forward-only via re-encryption under a future suite (section 14).

For callers who cannot accept that residual risk, v1.2 introduced the *opt-in* hybrid suite `0x06` (section 5). Suite `0x06` is IND-CCA2-secure as long as *either* ML-KEM-1024 *or* X25519 is IND-CCA2-secure; an attacker must break both to recover the session key. This is a separate suite allocation, not a modification of the core promise — the wire is unambiguous about which guarantee a given envelope makes.

2 Wire Format (Normative)

Big-endian throughout. **Header: fixed 16 bytes. Body: variable.**

```
Offset  Size  Field                                                AD?
------  ----  ---------------------------------------------------  ----
0       6     TS          (timestamp_ms; provenance, not auth)     yes
6       1     VAR         (variant byte = 0x04 for v1)             yes
7       1     SUITE       (algorithm suite id; see sec04)          yes
8       2     CTR         (counter, monotonic per sender)          yes
10      2     KEM_CT_LEN  (big-endian unsigned, <= 4096)            yes
12      4     AD_LEN      (length of caller-supplied AD)           yes
16      N     KEM_CT      (KEM ciphertext, N = KEM_CT_LEN)          yes
16+N    A     AD          (caller AD, A = AD_LEN)                   yes (carried)
16+N+A  12    AEAD_NONCE  (derived from K_session; see sec07)       no  (derived)
...     M     AEAD_CT     (AEAD_E(K_aead, NONCE, PT))              ---
...     16    AEAD_TAG    (128-bit tag over header || KEM_CT || AD)---
...     32    COMMIT      (key-commitment tag; HMAC-SHA3-256)      ---
```

The first 9 bytes (`TS || VAR || CTR`) are layout-compatible with PQID and PQHash: a single `common/c/pqtk_header.h` pins those offsets across all three projects. Variant byte `0x04` is the first allocation from the previously-reserved `0x04–0xFE` range; PQID and PQHash decoders MUST reject `0x04`, and PQCrypt decoders MUST reject every byte except `0x04` in v1.

Length limits. `KEM_CT_LEN` maximum 4096 bytes (ML-KEM-1024 produces 1568; the cap defends against malformed inputs causing oversized allocation). `AD_LEN` maximum 65 536 bytes. Plaintext maximum 2^{32} bytes (4 GiB); v1 is not a streaming format.

Wire form for envelopes (binary). v1 ships binary-only on the wire. Text encodings (Base64URL, Crockford Base32) are deferred to v1.1 because envelopes are variable-length and the encoder logic differs from PQID's and PQHash's fixed-length encoders. Callers that need text representations should wrap with standard Base64URL at the transport layer.

3 Algorithm Suites

The `SUITE` byte at offset 7 selects a complete algorithm bundle. v1.x allocates three:

Suite	KEM(s)	AEAD	KDF
`0x01`	ML-KEM-1024	AES-256-GCM + UtC commit (32 B)	HKDF
`0x02`	ML-KEM-1024	ChaCha20-Poly1305 + UtC commit (32 B)	HKDF
`0x06`	X25519 + ML-KEM-1024 (section 5)	AES-256-GCM + UtC commit (32 B)	HKDF
`0x00`, `0x03`–`0x05`, `0x07`–`0xFF`	— reject —	—	—

The wire is unambiguous about which guarantee a given envelope makes: suites `0x01`/`0x02` commit to "post-quantum confidentiality, no classical fallback"; suite `0x06` commits to "post-quantum *or* classical confidentiality, the attacker must break both." Suite `0x06` is a *separate suite-byte allocation* (section 5); it is never an in-place modification of `0x01`/`0x02`. Callers select by passing the suite byte explicitly to `encrypt`; `decrypt` dispatches by the suite byte in the envelope header.

Why ML-KEM-1024 only, not ML-KEM-768? The core promise (`0x01`/`0x02`) has no hybrid safety net (see section 1). We buy the largest NIST-defined PQ margin (level 5, ∼AES-256-equivalent classical-search) at the cost of a 1568 B KEM ciphertext (vs 1088 B for ML-KEM-768). For envelope

use this ∼500 B difference is irrelevant; the security margin is not. Suite `0x06` keeps ML-KEM-1024 (not 768) for the same reason: even with X25519 as a backup, the PQ half of the hybrid should not be downgraded.

Why AES-256-GCM + UtC, not AEGIS or GCM-SIV? AEGIS-128L is 2–3× faster on modern x86 and ARM (rfc, 2025) but its RFC finalized only September 2025; library support is immature. AES-256-GCM has decade-scale review, AES-NI/VAES acceleration to ∼10 GB/s (Intel Corporation, 2025; Bernstein and Lange, 2025), and a settled commitment construction in UtC (Bellare and Hoang, 2022). GCM-SIV duplicates the misuse-resistance property that the deterministic-nonce-from-KDF already provides structurally (section 7). AEGIS-128L was evaluated for v1.2 (a hypothetical suite `0x03`) in PQCK-00020 and *deferred*: as of November 2026, AEGIS implementations were not yet polyglot-ready across Python, Go, Java, and OpenSSL. The byte remains reserved-future; revisit when verified implementations land in libcrux and `mlkem-native`.

Why HKDF-SHA3-256? SHAKE/Keccak is already vendored under `common/c/keccak.{h,c}` for PQHash; HKDF-SHA3 reuses that primitive and aligns with FIPS 203's internal use of Keccak. SHA-256 with SHA-NI is faster but creates two hash families to audit and certify.

No agility within a suite. A suite byte *is* a version: changing any algorithm requires a new suite byte. There is no negotiation. This matches PQID's and PQHash's immutable-variant-byte discipline and avoids the downgrade and cross-protocol attack surface of TLS-style negotiation (cf. Terrapin (Bäumer et al., 2023)).

4 ML-KEM-1024 Binding

PQCrypt invokes ML-KEM-1024 unchanged from FIPS 203 (fip, 2024): `KeyGen`, `Encaps(pk)` producing (K, c), and `Decaps(sk, c)` producing K (or an implicit-reject pseudorandom value on malformed c, per the Fujisaki–Okamoto wrapper). We do not modify the FO transform, do not add a combiner, and do not wrap ML-KEM in any further construction. The shared secret K from `Decaps` is fed directly to `HKDF-Extract` as IKM (section 7).

4.1 Tight QROM proof

ML-KEM-1024's IND-CCA2 security has a tight QROM proof under Module-LWE (Hofheinz et al., 2017; Don et al., 2022). PQCrypt inherits this directly. We make no assumption beyond what FIPS 203 already requires.

4.2 Implementation sources (v1.x, as shipped)

Language	ML-KEM-1024 source (pinned)	Constant-time claim
Python	`kyber-py >= 1.0`	vendor-documented; NCC Group audit Q2 2024
C	**OpenSSL 3.5+** `EVP_KEM` ML-KEM-1024	OpenSSL constant-time path; FIPS 140-3 candidate
Go	**Go 1.26 stdlib** `crypto/mlkem`	stdlib constant-time
Rust	`ml-kem = "0.3"` (RustCrypto, `MlKem1024`)	const-time documented; `#![forbid(unsafe_code)]`
C++	wraps the C library	inherits OpenSSL
TypeScript	`@noble/post-quantum`	const-time documented; pure JS
Java	**SunJCE** JEP 452 (*not* BouncyCastle)	JDK stdlib constant-time
CPython ext	mirrors `pqcrypt_fast.py` (v1.1)	inherits Python sources

Decisions worth flagging:

- *C uses OpenSSL 3.5+ `EVP_KEM`, not `mlkem-native`.* The earlier draft of this whitepaper named `mlkem-native` (Cryspen and PQ Code Package, 2025); the PQCK-00005 release note records the decision to switch. OpenSSL has a smaller audit surface for our deployment (we already link `libcrypto` for the AEADs), a FIPS 140-3 validation path, and ubiquitous packaging. `mlkem-native` remains the fallback for embedded targets that cannot link OpenSSL.
- *Java uses SunJCE (JEP 452), not BouncyCastle.* The JEP 452 `KEM` API landed in JDK 24 and provides ML-KEM-1024 as a first-class `KeyPairGenerator` algorithm. BouncyCastle 1.79+ remains a viable alternative but is not the v1.1 reference; this avoids the CVE-2025-1432 surface (section 10) in the default vendoring story.
- *Go uses stdlib `crypto/mlkem` (Go 1.26+), not `filippo.io/mlkem`.* The earlier external library was the v1 alpha intent; by the time v1.1 shipped, ML-KEM had landed in the Go stdlib and the dependency was eliminated.

The v1 alpha language set (Python, C, Go, Rust) is the minimum that exercises the spec across a readable reference (Python), a canonical ABI (C), a stdlib-heavy ecosystem (Go), and the strongest constant-time toolchain (Rust). C++, TypeScript, Java, and CPython ext joined in v1.1; see Appendix F for the release timeline.

4.3 The "Kyber" naming ban

ML-KEM (FIPS 203, August 2024) is wire-incompatible with the Kyber-r3 specification it descends from. PQCrypt's public APIs MUST NOT expose the token "Kyber" even where the upstream library uses it. Rename at the binding layer (e.g., `kyber-py.ML_KEM_1024` → `pqcrypt.MLKem1024`). The same discipline applies to the hybrid suite's classical half: only "X25519" appears in user-facing identifiers, never "Curve25519" or "ECDH."

5 Hybrid Suite 0x06 (Optional)

Suite `0x06` (v1.2, PQCK-00021) is the opt-in hybrid alternative to the pure-PQ suites. It is a *separate suite-byte allocation*, never an in-place modification of `0x01` or `0x02`: callers who want the unambiguous PQ-only brand promise of section 1 keep using `0x01`/`0x02`; callers who want a classical safety net against a Module-LWE structural break opt in to `0x06`. Both promises remain

available, and the wire is unambiguous about which one a given envelope makes.

5.1 Construction

Suite `0x06` runs ML-KEM-1024 and X25519 (Langley et al., 2016) as independent KEMs, then combines them with a SHAKE-256 (fip, 2015) combiner inspired by X-Wing (Connolly et al., 2025):

$$\begin{aligned}(K_{\text{mlkem}}, c_{\text{mlkem}}) &\leftarrow \text{ML-KEM-1024.Encaps}(pk_{\text{mlkem}})\\ (sk_{\text{eph}}, pk_{\text{eph}}) &\leftarrow \text{X25519.GenerateKeypair}()\\ K_X &\leftarrow \text{X25519.ECDH}(sk_{\text{eph}}, pk_{\text{x}})\end{aligned}$$

The session shared secret is:

$$K_{\text{session}} = \text{SHAKE-256}(\text{“pqcrypt v1 hybrid combiner”} \,\|\, K_{\text{mlkem}} \,\|\, K_X \,\|\, c_{\text{mlkem}} \,\|\, pk_{\text{eph}},\ 32 \text{ bytes})$$

K_{session} replaces `ss_mlkem` as the IKM for the HKDF schedule of section 7; the rest of the wire format and AEAD path is unchanged. `KEM_CT` on the wire carries $c_{\text{mlkem}} \,\|\, pk_{\text{eph}}$, total 1600 bytes (1568 + 32).

5.2 Sizes

Object	Size (bytes)	Composition
Hybrid public key	1 600	ML-KEM-1024 `pk` (1568) ‖ X25519 `pk` (32)
Hybrid private key	3 200	ML-KEM-1024 `sk` (3168) ‖ X25519 scalar (32)
Hybrid `KEM_CT`	1 600	ML-KEM-1024 `ct` (1568) ‖ X25519 ephemeral `pk` (32)
Hybrid seed (KAT reproducibility)	96	FIPS 203 $(d \,\|\, z)$ (64) ‖ X25519 scalar (32)

5.3 Security argument

The combiner is an IND-CCA2 KEM iff *either* component KEM is IND-CCA2-secure under the assumption that SHAKE-256 is a random oracle for the combiner's input. This is the conservative “OR-style” hybrid: an attacker must break *both* ML-KEM-1024 *and* X25519 to recover K_{session}. The conservative direction matches X-Wing (Connolly et al., 2025) and is the consensus design for transport hybrids (TLS 1.3 `X25519MLKEM768`, OpenSSH `mlkem768x25519-sha256`, MLS RFC 9420 `X25519MLKEM768`). Including *both* ciphertext halves (c_{mlkem} and pk_{eph}) in the combiner input prevents an attacker who controls one half from forcing a known K_{session} even with full control of the other half.

5.4 Cost

One additional X25519 keygen plus one X25519 ECDH per envelope on encrypt; one X25519 ECDH per envelope on decrypt. On Apple M4 Max with the Go stdlib `crypto/ecdh`, the per-envelope amortized cost is approximately 50 µs on top of the ML-KEM-1024 baseline (section 13). `KEM_CT` grows by 32 bytes per envelope.

5.5 Constant-time and supply-chain posture

The X25519 implementation must be constant-time on the scalar multiplication. Verified per language: `x25519-dalek` v2 (Rust, `#![forbid(unsafe_code)]`), Go stdlib `crypto/ecdh` (constant-time on aarch64 and x86_64), Python `cryptography` (libsodium-backed). Hybrid-capable language ports: Python (PQCK-00021, v1.2), Rust (PQCK-00028, v1.3), Go (PQCK-00029, v1.3); C, C++, TypeScript, Java, and the CPython extension reject suite `0x06` as `UNKNOWN_SUITE` until their v1.4 ports land. See section 12 for the harness-level skip discipline.

When to opt in to suite `0x06`

Use suite `0x06` when the deployment's threat model includes "Module-LWE may turn out to be structurally weaker than believed" and the operator wants belt-and-suspenders coverage. Use suites `0x01`/`0x02` when the deployment wants an unambiguous post-quantum confidentiality promise (FIPS 203 NIST level 5 alone) and treats the residual Module-LWE risk as acceptable (section 1). Both promises remain on the wire; the suite byte names which one the envelope makes.

6 AEAD and Commitment

6.1 Why a separate commitment tag

AES-256-GCM and ChaCha20-Poly1305 are confidentiality-and-integrity AEADs but *not* key-committing (Grubbs et al., 2017): an attacker with two different keys can produce a single ciphertext that decrypts correctly under both. Weaponized variants (Albertini et al., 2020; Len et al., 2021) matter most in multi-recipient settings where the same envelope reaches recipients holding different keys — e.g., the exact class of bug `age` still has open in 2026. PQCrypt closes this with an explicit 32-byte commitment tag.

6.2 The UtC construction (Bellare & Hoang 2022)

Given the HKDF pseudorandom key `prk` from section 7, derive two subkeys:

$$K_{\text{aead}} = \text{HKDF-Expand}(\texttt{prk}, \text{“pqcrypt v1 aead k”}, 32)$$
$$K_{\text{commit}} = \text{HKDF-Expand}(\texttt{prk}, \text{“pqcrypt v1 commit”}, 32)$$

Encrypt under K_{aead} as usual, producing `AEAD_CT` and `AEAD_TAG`. Then compute:

$$\text{COMMIT} = \text{HMAC-SHA3-256}(K_{\text{commit}},\ \text{header} \,\|\, \text{KEM_CT} \,\|\, \text{AD} \,\|\, \text{AEAD_CT})$$

The 32-byte `COMMIT` appears as the final field on the wire (section 2).

6.3 Verification

Decryption verifies both `AEAD_TAG` (covering header, `KEM_CT`, AD, `AEAD_CT`) and `COMMIT` (covering header, `KEM_CT`, AD, `AEAD_CT`) in constant time before returning the plaintext. Both checks MUST execute even on early-detectable structural errors (truncated input, bad header magic) to keep timing flat; the implementation uses a synthetic key on structural failure paths.

6.4 Why UtC over CTX, GCM-SST, or compactly-committing schemes

CTX (Chan and Rogaway, 2022) is gaining adoption (libsodium 1.0.21, MLS) and shares UtC's tag-then-commit shape. UtC was chosen for v1 because (a) the original Bellare–Hoang proof is the most cited reference in subsequent literature, (b) its construction is simplest to implement in eight languages without crypto-library help, and (c) the 32-byte overhead matches our wire-format budget comfortably. GCM-SST (Hoang and Tessaro, 2024a) is academic-only as of 2026. Compactly-committing AEADs (Grubbs et al., 2017) are more space-efficient but introduce a non-standard cipher dependency.

6.5 Commitment vs content binding

The UtC commitment binds the AEAD key to the ciphertext — it answers the question "can the same ciphertext open to different plaintexts under different keys?" (no, by the commitment). It does *not* answer "does this ciphertext correspond to a specific known plaintext content?". That question is answered by binding a PQHash (the SHAKE-256-based content-hash sibling format under the pqtoolkit monorepo; variant byte `0x03`) as the AEAD AD: a PQCrypt envelope whose AD is the PQHash of the plaintext is cryptographically bound to that specific content. The two bindings are independent and stack cleanly: UtC closes multi-recipient confusion; PQHash-as-AD closes content substitution. See section 8 for the AD-binding patterns including PQID-as-AD and PQHash-as-AD.

7 Key Derivation and Deterministic Nonce

7.1 Key schedule

Let `ss_session` be the 32-byte session shared secret. For suites `0x01`/`0x02` it is `ss_mlkem` (the value returned by ML-KEM-1024 `Decaps`, or `Encaps` on the sender side); for suite `0x06` it is the SHAKE-256 combiner output defined in section 5. The downstream schedule is identical:

$$\begin{aligned}
\text{salt} &= \text{SHAKE256}(\text{“pqcrypt v1 header”} \,\|\, \text{header_bytes}[0{:}16],\ 32) \\
\text{prk} &= \text{HKDF-Extract}(\text{salt},\ \texttt{ss_session}) \\
K_{\text{aead}} &= \text{HKDF-Expand}(\text{prk},\ \text{“pqcrypt v1 aead k”},\ 32) \\
\text{NONCE} &= \text{HKDF-Expand}(\text{prk},\ \text{“pqcrypt v1 aead n”},\ 12) \\
K_{\text{commit}} &= \text{HKDF-Expand}(\text{prk},\ \text{“pqcrypt v1 commit”},\ 32)
\end{aligned}$$

The PRF is HMAC-SHA3-256 (fip, 2015). The same label strings are used for every suite — the suite byte enters the schedule via the salt (which binds the full header, including the suite byte) rather than via separate labels, so an attacker who tries to re-tag a `0x01` envelope as `0x06` (or vice versa) gets a different `salt`, a different `prk`, and AEAD verification failure.

7.2 Salt binding

The salt mixes a 16-byte project-and-version constant with the full envelope header (timestamp, variant, suite, counter, KEM CT length, AD length). Any header bit-flip therefore invalidates K_{aead} before the AEAD tag is even checked, providing a second line of defense against header tampering. The constant prevents cross-protocol reuse of the KDF.

7.3 Why deterministic nonce

Each ML-KEM-1024 encapsulation produces a fresh ephemeral shared secret, so K_{aead} is unique per envelope. For hybrid suite `0x06` (section 5), the X25519 ephemeral keypair is also freshly generated per envelope and the SHAKE-256 combiner produces a fresh K_{session} regardless of which component KEM is broken. Deterministic derivation of `NONCE` from `prk` therefore cannot cause nonce reuse under the same key on any suite. This:

- Removes the encrypt-side CSPRNG dependency beyond ML-KEM's internal `Encaps` randomness.
- Matches PASETO v4.local's philosophy (Arciszewski, 2021): deterministic derivation under a per-message fresh key is structurally safer than per-message random nonce generation.
- Eliminates a class of misuse: an implementer who accidentally reuses a CSPRNG seed cannot create a nonce-collision oracle, because the seed cannot survive ML-KEM `Encaps` (fip, 2024).

7.4 Multi-user / multi-key bounds

The single-key birthday bound on AES-256-GCM is 2^{64} blocks; PQCrypt's plaintext cap of 2^{32} bytes per envelope keeps each invocation well below the bound. The multi-user attack analysis of Bose, Hoang, and Tessaro (Bose et al., 2018; Hoang and Tessaro, 2024b) concerns adversaries who attack many keys simultaneously; PQCrypt's per-envelope fresh K_{aead} removes the long-key-lifetime axis of that attack class.

8 The PQID-as-AD Canonical Pattern

PQCrypt's existence as a sibling of PQID and PQHash in the same monorepo is not aesthetic — it is structural. The canonical usage pattern is to bind a PQID as the AEAD's associated data:

```
record_id = pqid.new_hlc()                                  # 41 bytes
envelope  = pqcrypt.encrypt(plaintext, recipient_pub,
                            associated_data=record_id)
# ... later, after delivery ...
plaintext = pqcrypt.decrypt(envelope, recipient_priv,
                            expected_ad=record_id)          # MUST match
```

What this defends. An attacker who reroutes the envelope under a different PQID cannot decrypt it: AEAD tag verification fails (AD mismatch) and the decryption path returns the generic `DecryptionError` (section 9). The envelope is cryptographically bound to the identifier it was issued for.

Cost. Free. Every AEAD's AD path is computed at no marginal cost beyond the bytes being mixed into the MAC. PQCrypt's bench measurement `encrypt_with_pqid_ad` confirms this experimentally (section 14).

Cross-project AD patterns. Other useful AD choices:

- A PQHash of the plaintext, for envelopes that explicitly bind to content (defense against substituting one record's envelope onto another record).

- A concatenation of a PQID and a recipient identifier, for envelopes addressed to a specific (record, recipient) pair.
- A protocol-level domain separator (e.g., `"pqcrypt-app-v1-records"`) plus the PQID.

Conformance. The KAT file `pqcrypt/conformance/vectors/ad_binding.json` exercises positive cases (envelope decrypts with the matching AD) and negative cases (any single-bit AD change causes a generic `DECRYPT_FAILED`, with timing equal to the positive case to within the constant-time tolerance defined in section 10).

9 Failure Modes

9.1 One error class for every authentication-class failure

PQCrypt's `decrypt` API returns exactly one error category for every failure where the attacker could be probing for an oracle: `DecryptionError` (Python, TypeScript, Java) / `PQCRYPT_E_DECRYPT_FAILED` (C ABI) / `Error::Decrypt` (Rust). The categories that map to this single error:

- Bad AEAD tag.
- Bad UtC commitment tag.
- Bad KEM ciphertext (ML-KEM implicit-reject path).
- AD mismatch.
- Unknown variant inside a decrypted internal blob (reserved for future suite-version embeds).

The categories that map to distinct *structural* errors and may be distinguished safely:

- Truncated envelope or impossible length field (`INVALID_LEN`).
- Unknown variant byte at offset 6 (`UNKNOWN_VARIANT`).
- Unknown suite byte at offset 7 (`UNKNOWN_SUITE`). For non-hybrid-capable language ports (v1.x), suite `0x06` is rejected here.
- Suite/key mismatch (`BAD_KEY`). `encrypt` rejects when the recipient public key's suite does not match the requested suite; `decrypt` rejects when the private key's suite does not match the envelope's header suite. This is structural — it does not touch secret-correlated bytes — and distinguishable safely.
- Output buffer too small (C ABI only: `BUF_TOO_SMALL`).

9.2 Constant-time discipline

Even on structural failure paths, the decrypt routine MUST execute the AEAD verify against a synthetic 32-byte key to keep timing flat. The reference implementation uses `HKDF_Expand(prk_zero, "pqcrypt v1 timing pad", 32)` where `prk_zero` is a 32-byte all-zero buffer.

9.3 Timing-histogram regression

`pqcrypt/conformance/vectors/` ships a 100 000-pair timing dataset (50 000 good envelopes, 50 000 "bad" envelopes with single-bit flips in eight different positions). The conformance runner measures decrypt-path latency for each and asserts:

- Median difference between good and bad timing < 50 ns (on the reference hardware: Apple M3 Max @ 4.05 GHz P-core).
- 99th-percentile difference < 500 ns.

The runner uses `clock_gettime(CLOCK_MONOTONIC_RAW)` where available; falls back to `time.perf_counter_ns()` (Python), `Instant::now()` (Rust), or `time.Now()` (Go).

9.4 Implicit-reject semantics

The FO transform in ML-KEM-1024 (fip, 2024; Hofheinz et al., 2017) returns a pseudorandom 32-byte value on malformed ciphertext rather than raising an error. PQCrypt preserves this: a bad `KEM_CT` produces an implicit-reject `ss_mlkem`, which is then expanded into a useless K_{aead}, which then fails AEAD tag verification, which finally produces the generic `DecryptionError`. The attacker cannot distinguish "bad KEM CT" from "bad AEAD tag" from "bad commit tag" from "AD mismatch."

10 Side Channels

10.1 Known attacks 2024–2026

- **KyberSlash 1 & 2** (Bernstein et al., 2024), Dec 2023 / Jan 2024: division-by-secret timing leak in ML-KEM `Decaps` and `poly_compress`. Patched in pq-crystals reference and liboqs 0.10 in January 2024. PQCrypt vendors only post-patch implementations.
- **PQShield power-analysis disclosure** (PQShield, 2024), Mar 2024: SPA on Cortex-M4 ML-KEM `Decaps` recovering the secret in fewer than 1000 traces. Mitigations live in `mlkem-native`'s masking branch; not used by default in v1.
- **SPA-CCA on ML-KEM** (Guo et al., 2024), ePrint 2024/2051: single-trace CCA on unmasked Cortex-M4. Masked implementations unaffected.
- **CVE-2024-39427** (liboqs $< 0.10.1$, Jul 2024): ML-KEM `Decaps` timing on certain platforms. Fixed pre-v1.
- **CVE-2025-1432** (Bouncy Castle 1.78, Feb 2025): ML-KEM rejection-sampling bias on malformed public keys. Fixed in BouncyCastle 1.79+. The v1.1 Java port avoids the surface entirely by using SunJCE JEP 452 (JDK 24+) as the ML-KEM source rather than BouncyCastle (section 4); a BouncyCastle-backed alternative remains usable but must pin $\geq$ 1.79.

10.2 What v1 mitigates

PQCrypt v1.x mitigates software-timing side channels by:

- Vendoring constant-time ML-KEM-1024 implementations per language (section 4). For hybrid suite `0x06` (section 5), the X25519 source is similarly pinned per language to a constant-time implementation: `x25519-dalek` v2 in Rust (`#![forbid(unsafe_code)]`), Go stdlib `crypto/ecdh` (constant-time on aarch64 and x86_64), Python `cryptography` (libsodium-backed). Small-subgroup / low-order point inputs are rejected structurally by the X25519 library and surface as `DecryptionError` via the constant-time decrypt wrapper.
- Constant-time AEAD tag and commitment tag verification (sections 6 and 9).
- A single `DecryptionError` class covering every authentication-related failure.
- Timing-histogram regression vectors in conformance (section 9).

10.3 What v1 does *not* mitigate

Constant-time is not constant-power

PQCrypt v1 does not mitigate power-analysis, electromagnetic-emanation, frequency-scaling (Wang et al., 2022; Chen et al., 2024), or prefetcher (Chen et al., 2024) side channels. Deployment in environments where an attacker can measure CPU power, EM, frequency, or memory-prefetcher behavior — smart cards, embedded devices, shared multi-tenant hosts without DOIT-class mitigations (Intel Corporation, 2022) — requires additional countermeasures outside the library's scope.

The companion document `pqcrypt/docs/side-channel-disclaimer.md` restates these limits in operator-facing language and links to recommended hardware-isolation patterns for high-assurance deployments.

10.4 Forward path

A future suite byte (drawn from the remaining reserved-future range; suite `0x06` is now taken for hybrid, section 5) could pin a masked ML-KEM-1024 implementation as mandatory for high-assurance deployments where power-analysis is in scope. The variant-byte and suite-byte allocation discipline supports this without breaking v1.x envelopes (section 14).

11 Plugin Protocol

11.1 Why a plugin protocol in v1

PQCrypt's core spec does *not* define a key-on-disk format. Specifying one in v1 would require choosing a passphrase KDF (Argon2id parameters), a wrapping cipher, a versioning byte, and a textual armor format — each a non-trivial decision that ages on a different clock than the wire format itself. The lesson from `age`'s ecosystem is that this work belongs to plugins (`age-plugin-yubikey`, `age-plugin-tpm`, `age-plugin-se`, `age-plugin-fido2`). PQCrypt ships the plugin protocol so plugin authors can build immediately, plus a reference plugin (`pqcrypt-plugin-file`, section 11.3) so the v1 spec is self-contained.

11.2 Wire format

The plugin protocol uses stdin/stdout binary frames modeled on the C2SP `age-plugin` specification (C2SP, 2023). The PQCrypt library invokes `pqcrypt-plugin-<name>` via `exec`, passes envelope-level data through framed messages, and receives wrapped/unwrapped key material in return.

Frames are length-prefixed: 4-byte big-endian length, then the frame body. Frame types are identified by a leading single-byte tag. v1 frame types:

- `RECIPIENT_STANZA` (`0x01`): declares the plugin's recipient identifier in URI form `pqck1<plugin-name>1<base6`
- `WRAP_KEY` (`0x02`): library → plugin, requesting wrap of a per-envelope file-key.
- `UNWRAP_KEY` (`0x03`): library → plugin, requesting unwrap of a previously-wrapped file-key.
- `OK` (`0x10`): plugin → library, success with body payload.
- `ERROR` (`0x11`): plugin → library, failure with optional explanatory string.

The full state machine, including handshake and pipelining rules, is defined in `pqcrypt/plugin/pqcrypt-plugin-pr`

11.3 Reference plugin: `pqcrypt-plugin-file`

`pqcrypt-plugin-file` stores a passphrase-wrapped ML-KEM-1024 private key on disk. The current on-disk format is `pqck-key-v1.1` (PQCK-00018, v1.1); the older `pqck-key-v1` format remains readable for backwards compatibility. Construction:

1. Read the passphrase from the terminal (no echo) or from `$PQCRYPT_PASSPHRASE`.
2. Derive a 32-byte symmetric key: `K_wrap = Argon2id(passphrase, salt, m=64MiB, t=3, p=1, 32 bytes)` (rfc, 2021).
3. Wrap the ML-KEM-1024 private key (∼3168 B; or 3200 B for a hybrid keypair, section 5) under AES-256-GCM: `wrapped = AES-256-GCM-Encrypt(K_wrap, nonce, sk)` where `nonce` is 12 fresh CSPRNG bytes.
4. Serialize: `pqck-key-v1.1\n<base64url(salt ‖ nonce ‖ wrapped ‖ tag ‖ public_key)>\n`.

Why v1.1 embeds the public key. A v1.0 keyfile required passphrase unwrap before the plugin could answer a `pubkey` query, which the CLI binary (PQCK-00022, see below) exercises on every recipient lookup. v1.1 stores the unencrypted public key alongside the wrapped private key so plugins can answer `pubkey` without prompting for a passphrase. The public key was never secret; only the private-key wrap is.

Reference CLI. A reference CLI binary ships in v1.2 (PQCK-00022): `python -m pqcrypt.cli {keygen,pubkey,encrypt,decrypt,info}`. It invokes `pqcrypt-plugin-file` via subprocess for every key-custody operation; no private key material is ever read from `argv`.

The reference plugin is not part of the v1 normative wire format; only the plugin *protocol* is. Other plugins (`pqcrypt-plugin-yubikey`, hypothetical) may wrap keys however they want.

11.4 What the protocol does *not* cover

- Key custody (HSM, secure enclave, TPM): a job for plugin authors.

- Key rotation: a higher-level concern; PQCrypt envelopes are self-contained and do not encode rotation lineage.
- Plugin trust: PQCrypt invokes whichever plugin binary the caller's PATH resolves; the caller is responsible for trusting that binary.

12 Conformance

12.1 KAT vector files

`pqcrypt/conformance/vectors/`:

- `encrypt_roundtrip.json` — fixed-RNG-seed determinism. Each record gives a plaintext, a recipient public key, a sender RNG seed, and an expected envelope hex.
- `decrypt.json` — known envelopes → known plaintexts, exercising the decrypt path for suites `0x01` and `0x02`.
- `peek_header.json` — header parsing without authentication.
- `invalid.json` — bad variant byte (covering 0x00, 0x01, 0x02, 0x03, 0x05–0xFF), bad suite byte, truncated `KEM_CT`, bad AEAD tag, bad commit tag, bad AD.
- `ad_binding.json` — PQID-as-AD positive and negative cases.
- `commitment.json` — UtC commit tag KATs independent of the AEAD path.
- A KyberSlash-class timing-regression vector (working name `kyberslash_regression.json`) — known-bad ML-KEM-1024 inputs that exercised KyberSlash 1/2 (Bernstein et al., 2024), asserting they reject without timing variance — is *planned* (backlog) and is *not* yet part of the shipped vector set.
- `min_timestamp.json` — `MIN_TIMESTAMP_MS` helper parity (mirrors PQID's and PQHash's analogous files).
- `hybrid_decrypt.json` — KAT round-trip for hybrid suite `0x06` (4 records).
- `hybrid_ad_binding.json` — hybrid AD-binding positive and negative cases (4 records).
- `hybrid_peek_header.json` — hybrid header parse (1 record).

12.2 Cross-language runner

Vectors are consumed by the same harness used by PQID and PQHash: `tools/conformance/run.sh`. The script discovers per-language runners (`tools/conformance/python/`, `.../c/`, `.../go/`, `.../rust/`) and executes each against each vector file. Exit code 0 means every runner passed every vector. Language ports without their own `pqcrypt_runner` fall back to the Python runner for PQCrypt vectors via the harness's `pqcrypt_runner_cmd` empty case (PQCK-00015).

12.3 Hybrid suite `0x06` skip discipline

`tools/conformance/run.sh` filters `hybrid_*.json` vector files per language via `hybrid_supported()`:

```
hybrid_supported() {
    case "$1" in
        python) return 0 ;;   # PQCK-00021, v1.2
        rust)   return 0 ;;   # PQCK-00028, v1.3
        go)     return 0 ;;   # PQCK-00029, v1.3
        *)      return 1 ;;   # C/C++/TS/Java/CPython ext: v1.4 backlog
    esac
}
```

Languages without hybrid skip the `hybrid_*.json` files entirely and MUST reject suite `0x06` as `UNKNOWN_SUITE` for any non-hybrid envelope. When porting hybrid to a new language: (1) implement hybrid in the language, (2) update the language's conformance runner to accept 96-byte seeds (section 5), (3) flip the language's `hybrid_supported()` entry, (4) verify the language's PASS count rises by 9 (one per record across the three `hybrid_*.json` files).

12.4 Local invocation

```
bash tools/conformance/run.sh
PQTK_CONFORMANCE_SKIP="cpython java cpp typescript" bash
    tools/conformance/run.sh
```

Latest state (v1.3, 2026-05-21, Apple M4 Max):

Language	PASS	FAIL	Notes
Python	265	0	256 standard + 9 hybrid
C	256	0	hybrid skipped (v1.4 backlog)
Go	265	0	256 + 9 hybrid (PQCK-00029)
Rust	265	0	256 + 9 hybrid (PQCK-00028)

C++, TypeScript, Java, and the CPython extension consume PQCrypt vectors via the Python runner fallback and skip `hybrid_*.json`.

12.5 Branch-protection gate

The GitHub Actions workflow `.github/workflows/conformance.yml` runs the full harness across all three projects (PQID, PQHash, PQCrypt). It is a required check for merging to `main`.

12.6 Vector generation

All vectors are generated against the Python reference (`pqcrypt/python/pqcrypt.py`). The generator script lives at `pqcrypt/conformance/scripts/generate.py`. Vectors are committed verbatim: re-running the generator on the same code MUST produce identical JSON. If a code change produces different vectors, that is a spec change and requires a release-notes entry plus updates to every language implementation.

13 Comparison with Existing Formats

A grounded marketplace view as of November 2026. PQCrypt is the only envelope format in the table that offers *both* (a) a pure-PQ option (suites `0x01`/`0x02`) and (b) a key-committing AEAD

— with a hybrid alternative (suite `0x06`) layered on the same wire format for callers who want defense-in-depth.

13.1 Envelope formats

Format	Algorithms (2026)	PQ status	Commit	Notes
age v1.2.1 (Valsorda and contributors, 2025)	X25519 + ChaCha20-Poly1305	Experimental plugin only	No	Multi-recipient confusion class still open
Tink v1.17 (Google, 2026)	AES-GCM, AES-GCM-SIV, ChaCha20-Poly, HPKE RFC 9180	ML-KEM tracked, not GA upstream	No	Library, no file-format spec
PASETO v4.local (Arciszewski, 2021)	XChaCha20 + BLAKE2b-MAC (EtM)	None	Yes (by construction)	Inspired our deterministic-nonce + separate-MAC
HPKE-PQ draft 09 (Wood et al., 2026)	X-Wing (X25519 + ML-KEM-768)	Hybrid (KEM 0x647A)	No	The agility-camp answer to the same problem
MLS RFC 9420 (rfc, 2023)	X25519 MLS ciphersuite	Hybrid ML-KEM-768	No	Group messaging, not file
Signal PQXDH (Kret and Schmidt, 2023)	X25519 + Kyber-1024	Hybrid (legacy Kyber)	No	Messaging handshake
Apple iMessage PQ3 (Apple Security Engineering and Architecture, 2024)	ECDH P-256 + Kyber-1024 + rekey	Hybrid (legacy Kyber)	No	Production scale (∼1B devices)
AWS KMS PQ TLS (Amazon Web Services, 2024)	ML-KEM-	Transport hy-	N/A	Not an

The cross-format point: every other hybrid PQ format in 2026 (HPKE-PQ, MLS, Signal, Apple PQ3) is *exclusively* hybrid; every other pure-PQ envelope-shaped artifact is academic. PQCrypt is the only deployed envelope spec that offers *both* a pure-PQ promise and an opt-in hybrid promise on the same wire, distinguished by a single byte. This dual-promise design draws directly on the immutable-variant-byte discipline that PQID (variants `0x01`/`0x02`) and PQHash (variant `0x03`) established earlier in the pqtoolkit monorepo: a byte *is* a version, never a renegotiation surface.

13.2 KEM cost (Zen 4, cycles; sizes in bytes)

KEM	NIST	Keygen	Encaps	Decaps	pk	sk	ct	Source
ML-KEM-512	1	18 800	22 400	18 200	800	1 632	768	(PQ Code Packag
ML-KEM-768	3	30 100	35 900	29 400	1 184	2 400	1 088	(PQ Code Packag
ML-KEM-1024 (PQCrypt v1)	**5**	**46 200**	**54 800**	**45 300**	**1 568**	**3 168**	**1 568**	(PQ Code Packag
HQC-128	1	142 000	256 000	384 000	2 249	2 305	4 433	(HQC Submissior
Classic McEliece 348864	1	1.4×10^8	73 000	132 000	261 120	6 492	96	(Classic McEliece

13.3 AEAD throughput (1 MiB, single thread, GB/s)

AEAD	Sapphire R.	Zen 4	Apple M3	Notes
AES-256-GCM (PQCrypt v1)	**10.3**	**9.7**	**6.8**	AES-NI/VAES
AES-256-GCM-SIV	6.1	5.4	3.9	Extra GHASH pass
ChaCha20-Poly1305 (PQCrypt suite 0x02)	5.8	3.4	3.1	AVX-512 path on x86
AEGIS-128L	28.4	26.1	14.7	RFC 9678 Sep 2025
AEGIS-256	18.9	17.2	10.4	RFC 9678 Sep 2025
Ascon-128a (FIPS 232 final, Aug 2025)	0.55	0.52	0.61	Lightweight, constrained HW

Sources: (Bernstein and Lange, 2025; Intel Corporation, 2025; rfc, 2025). AEGIS is 2–3× faster than AES-256-GCM. It was evaluated for v1.2 at suite `0x03` (PQCK-00020) and *deferred*: as of November 2026 verified AEGIS implementations are not yet polyglot-ready across Python, Go, Java, and OpenSSL. Revisit when verified implementations land.

13.4 Reference benchmarks (Apple M4 Max, ops/sec, v1.3)

End-to-end PQCrypt operations as measured by the per-language bench harnesses on Apple M4 Max (single P-core, release builds). Numbers are ops/sec; higher is better. "Hybrid" rows refer to suite `0x06` (section 5).

Operation	Python	C	Go	Rust
keygen (ML-KEM-1024)	398	24 921	24 666	11 530
keygen (hybrid `0x06`)	388	— v1.4	17 521	8 073
encrypt 1 KiB (AES-256-GCM)	342	20 966	20 788	9 372
encrypt 1 KiB (hybrid `0x06`)	305	— v1.4	10 000	4 653
decrypt 1 KiB (AES-256-GCM)	259	8 689	20 232	17 686
decrypt 1 KiB (hybrid `0x06`)	248	— v1.4	13 724	11 485
encrypt 1 MiB (AES-256-GCM)	232	447	685	131
decrypt 1 MiB (AES-256-GCM)	202	405	701	135

Read: Go's PQCrypt port is the fastest because Go 1.26 stdlib `crypto/aes` routes through ARMv8 AES instructions on Apple Silicon automatically and the GC compiler inlines the ML-KEM hot path tightly. C trails Go on `decrypt 1 KiB` because the OpenSSL `EVP_KEM Decaps` path performs an additional dispatch step. Rust's 1 MiB throughput is regressed because `aes-gcm 0.10` does not enable ARMv8 AES intrinsics on stable Rust without a nightly `target_feature` cfg; this is tracked as PQCK-00027 (deferred to v1.4) and is expected to recover to C-class throughput once `aes-gcm 0.11` ships. Hybrid encrypt is roughly 2× slower than the AES-only path because each envelope adds one X25519 ephemeral keygen and one DH; hybrid decrypt adds only one DH.

13.5 Deployment scale (Nov 2026)

- Cloudflare Radar (Apr 2026): ∼38% of outbound TLS 1.3 to origins uses `X25519MLKEM768`; ∼32% of inbound from browsers (Cloudflare, 2026).
- Chrome: `X25519MLKEM768` default-on Chrome 131 (Nov 2024); `X25519Kyber768` fully removed in Chrome 141.
- OpenSSH 10.0 (Apr 2025): `mlkem768x25519-sha256` default key exchange.
- Apple iMessage PQ3: iOS 17.4 (Mar 2024), ∼1B devices.
- Signal PQXDH: mandatory client ≥ Sep 2023.
- AWS KMS PQ TLS to endpoints: GA Oct 2024.
- GCP Cloud KMS: PQ signing GA Feb 2026, PQ KEM preview.

The ecosystem reality: hybrid (X-Wing or TLS-style concat) has won the transport-protocol fight. PQCrypt is deliberately a counter-example for the envelope-format niche where unambiguous "PQ-only" is a feature, not a bug.

14 Appendices

A. Residual-risk acknowledgment for the pure-PQ core promise

PQCrypt's core promise (suites `0x01` and `0x02`) is post-quantum-only. If ML-KEM-1024 is later structurally broken (a sub-exponential Module-LWE attack), every `0x01`/`0x02` envelope loses confidentiality with no classical fallback. This is a 30–50 year risk accepted in exchange for the unambiguous PQ-only promise. The mitigation path is now operational rather than aspirational:

1. Suite byte `0x06` (PQCK-00021, v1.2; section 5) is the opt-in hybrid suite (X25519 + ML-KEM-1024 + AES-256-GCM + UtC). Callers who want belt-and-suspenders coverage select `0x06` at `encrypt` time. The wire byte at offset 7 records which promise the envelope makes.
2. Long-lived ciphertexts written under suites `0x01`/`0x02` can be re-encrypted under `0x06` (or a future suite) within a defined window. PQCrypt v1.x is not an archive format; long-lived storage should plan re-encryption.
3. Suite `0x01`/`0x02` decoders remain available indefinitely (suite bytes are immutable post-allocation, matching the variant-byte discipline of PQID and PQHash).

We do *not* mitigate by hedging suites `0x01`/`0x02` themselves. The pure-PQ promise of those suites is preserved verbatim from v1.0; the hybrid escape valve sits in a separate suite-byte allocation. This is the design choice that lets the same wire format carry two distinct guarantees without diluting either.

B. Variant byte allocation across pqtoolkit

Byte	Owner	Meaning	Status
`0x00`	—	Permanently reserved	MUST reject
`0x01`	PQID	Standard generator	assigned
`0x02`	PQID	HLC generator	assigned
`0x03`	PQHash	SHAKE-256 / 64 B tail	assigned
`0x04`	PQCrypt	Encryption envelope v1	assigned (this document)
`0x05`–`0xFE`	—	Reserved-future	MUST reject
`0xFF`	—	Permanently reserved	MUST reject

Cross-rejection is normative: PQID and PQHash decoders MUST reject `0x04`; PQCrypt decoders MUST reject `0x01`, `0x02`, `0x03`, and every byte in `0x05`–`0xFF` in v1. Each project's `invalid.json` conformance file pins the cross-rejection.

C. Suite byte allocation

Suite	Algorithms	Status
`0x01`	ML-KEM-1024 + AES-256-GCM + UtC commit + HKDF-SHA3-256	v1.0 mar
`0x02`	ML-KEM-1024 + ChaCha20-Poly1305 + UtC commit + HKDF-SHA3-256	v1.0 opti
`0x06`	X25519 + ML-KEM-1024 + AES-256-GCM + UtC commit + HKDF-SHA3-256	v1.2 opti
`0x00`, `0x03`–`0x05`, `0x07`–`0xFF`	Reserved-future	MUST r

Earmarked future suites (not normative in v1.x):

- `0x03`: ML-KEM-1024 + AEGIS-128L + UtC commit. Evaluated and deferred in PQCK-00020 (Nov 2026): AEGIS libraries not yet polyglot-ready. The byte remains reserved-future; revisit when libcrux, OpenSSL, and Go stdlib all ship verified AEGIS implementations.
- `0x07`: HQC + AES-256-GCM + UtC commit (lattice-fatigue backup, would only land if Module-LWE confidence falters).
- Hardened-implementation variants (masked ML-KEM, side-channel-protected X25519) would each take a new suite byte rather than modify `0x01`/`0x02`/`0x06`.

D. Test-vector schema

Each KAT file is a JSON array of records. Common fields:

```
{
  "name":         "human-readable id, unique within the file",
  "op":           "encrypt | decrypt | peek_header | commit | ...",
  "input_hex":    "raw bytes for decode-from-binary ops",
  "input":        { ... op-specific structured input },
  "expected":     { ... op-specific structured output },
```

```
  "should_fail":  false,
  "error_kind":   "DECRYPT_FAILED | UNKNOWN_VARIANT | UNKNOWN_SUITE |
      INVALID_LEN"
}
```

Full schema in `pqcrypt/conformance/README.md`.

E. Acknowledgments

PQID and PQHash for the polyglot-spec-first discipline this whitepaper inherits. Bellare and Hoang for the UtC construction (Bellare and Hoang, 2022). The OpenSSL maintainers for the ML-KEM-1024 `EVP_KEM` integration shipped in OpenSSL 3.5; the RustCrypto `ml-kem` authors for the pinned Rust source; the Go core team for landing `crypto/mlkem` in the 1.26 stdlib; the `kyber-py` maintainers (NCC Group audit, Q2 2024); and the Cryspen team for `mlkem-native` (Cryspen and PQ Code Package, 2025), retained as the embedded-target fallback. The X25519 sources used by hybrid suite `0x06`: `x25519-dalek` v2 (Rust), Go stdlib `crypto/ecdh`, and `cryptography` (Python). The X-Wing draft authors (Connolly et al., 2025) for the combiner design idiom. The KyberSlash (Bernstein et al., 2024), PQShield (PQShield, 2024), SPA-CCA (Guo et al., 2024), and GoFetch (Chen et al., 2024) disclosure teams, whose findings shape the side-channel disclaimer.

F. Release timeline (v1.0 – v1.3)

Release	Date	Tickets	Headline
v1.0 alpha	2026-05-20	PQCK-00001–00010	Spec + Python/C/Go/Rust references + plugin protocol + cross-language conformance harness. Suites `0x01`/`0x02` only.
v1.1	2026-05-21	PQCK-00011–00019	C++ / TypeScript / Java / CPython ext ports; `.pqck-key-v1.1` keyfile format (embeds pubkey); CSPRNG path rewire; AEGIS-128L evaluation (deferred). C switched from `mlkem-native` to OpenSSL 3.5 `EVP_KEM`; Java switched from BouncyCastle 1.79+ to SunJCE JEP 452; Go switched from `filippo.io/mlkem` to stdlib `crypto/mlkem`.
v1.2	2026-05-21	PQCK-00020–00026	**Hybrid suite `0x06`** (Python only); reference CLI binary; GitHub Actions matrix; bench sweep; internal security audit doc; AEGIS deferral recorded.
v1.3 partial	2026-05-21	PQCK-00027–00029	Hybrid suite `0x06` ports to Rust (PQCK-00028) and Go (PQCK-00029). AES-NI/ARMv8 intrinsics deferral for Rust (PQCK-00027).

v1.4 backlog (not normative in this document): hybrid suite `0x06` ports to C (PQCK-00030), TypeScript (PQCK-00031), Java (PQCK-00032), CPython ext (PQCK-00033); Rust AES-NI/ARMv8 intrinsics reopen (PQCK-00034); CI timing-histogram regression test (PQCK-00035).

G. Author and document provenance

Author: Bahram Samani, `pqtoolkit` monorepo maintainer.

This document is built from LaTeX sources under `pqcrypt/latex/` (`main.tex` + `secNN_*.tex`);

the build chain is `pdflatex` → `bibtex` → `pdflatex` × `2` per the Makefile. The artifact at `pqcrypt/latex/PQCrypt_Whitepaper.pdf` is regenerated and committed alongside any normative change.

Authority order (when sources disagree): this whitepaper, then the Python reference at `pqcrypt/python/pqcrypt` then the canonical C ABI at `pqcrypt/c/pqcrypt.h`, then every other language. A cross-language disagreement is never resolved by changing the spec to match an outlier; the outlier is fixed.

Threat-model checklist: the internal pre-external-audit walk-through is at `pqcrypt/docs/security-audit-v1.2` (PQCK-00025). It enumerates open items for an external auditor (CI timing histogram, FIPS 140-3 path, synthetic-key timing-pad invariant testing, hybrid C port, plugin protocol fuzz harness, memory-zeroization audit).

Side-channel posture: this document and the companion `pqcrypt/docs/side-channel-disclaimer.md` are normative. v1.x mitigates software-timing side channels only; not power, EM, frequency-scaling, or prefetcher attacks.

Conformance gate: `tools/conformance/run.sh` is the branch-protection check. Latest run (2026-05-21, Apple M4 Max alpha quick loop): 1051 PASS, 0 FAIL across pqid + pqhash + pqcrypt, four alpha languages (section 12).

References

SHA-3 standard: Permutation-based hash and extendable-output functions. Technical Report FIPS PUB 202, National Institute of Standards and Technology, Aug. 2015. URL https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.202.pdf.

Argon2 memory-hard function for password hashing and proof-of-work applications, 2021. URL https://datatracker.ietf.org/doc/html/rfc9106.

The messaging layer security (MLS) protocol, 2023. URL https://datatracker.ietf.org/doc/html/rfc9420.

Module-lattice-based key-encapsulation mechanism standard. Technical Report FIPS PUB 203, National Institute of Standards and Technology, Aug. 2024. URL https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.203.pdf.

The AEGIS family of authenticated encryption algorithms, Sept. 2025. URL https://www.rfc-editor.org/rfc/rfc9678.

A. Albertini, T. Duong, S. Gueron, S. Kölbl, A. Luykx, and S. Schmieg. How to abuse and fix authenticated encryption without key commitment. IACR ePrint 2020/1456, 2020. URL https://eprint.iacr.org/2020/1456.

Amazon Web Services. Using post-quantum TLS with AWS KMS, 2024. URL https://docs.aws.amazon.com/kms/latest/developerguide/pqtls.html.

Apple Security Engineering and Architecture. imessage with PQ3: A new state of the art in quantum-secure messaging at scale, 2024. URL https://security.apple.com/blog/imessage-pq3/.

S. Arciszewski. PASETO v4.local specification, 2021. URL https://github.com/paseto-standard/paseto-spec/blob/master/docs/01-Protocol-Versions/Version4.md.

F. Bäumer, M. Dürmuth, and M. Brinkmann. Terrapin Attack: Breaking SSH channel integrity by sequence-number manipulation (CVE-2023-48795), 2023. URL https://terrapin-attack.com/.

M. Bellare and V. T. Hoang. Efficient schemes for committing authenticated encryption. In *Advances in Cryptology – EUROCRYPT 2022*, 2022. URL https://eprint.iacr.org/2022/1260.

D. J. Bernstein and T. Lange. eBACS: ECRYPT benchmarking of cryptographic systems (SUPERCOP), 2025. URL https://bench.cr.yp.to/.

D. J. Bernstein et al. KyberSlash 1 & 2: Timing-based key recovery on ML-KEM, 2024. URL https://kyberslash.cr.yp.to/.

P. Bose, V. T. Hoang, and S. Tessaro. Revisiting AES-GCM-SIV: Multi-user security, faster key derivation, and better bounds. IACR ePrint 2017/702, 2018. URL https://eprint.iacr.org/2017/702.

C2SP. The age plugin protocol, 2023. URL https://github.com/C2SP/C2SP/blob/main/age-plugin.md.

J. Chan and P. Rogaway. On committing authenticated encryption. IACR ePrint 2022/1260 (CTX construction), 2022. URL https://eprint.iacr.org/2022/1260.

B. Chen et al. GoFetch: Breaking constant-time cryptographic implementations using data memory-dependent prefetchers. USENIX Security 2024, 2024. URL https://gofetch.fail/.

Classic McEliece Submission Team. Classic McEliece: Implementation notes, 2022. URL https://classic.mceliece.org/mceliece-impl-20221023.pdf.

Cloudflare. Radar: Post-quantum TLS adoption, 2026. URL https://radar.cloudflare.com/adoption-and-usage.

D. Connolly, P. Schwabe, and B. Westerbaan. X-Wing: General-purpose hybrid post-quantum KEM. draft-connolly-cfrg-xwing-kem, IETF CFRG, 2025. URL https://datatracker.ietf.org/doc/draft-connolly-cfrg-xwing-kem/.

Cryspen and PQ Code Package. mlkem-native: Formally verified ML-KEM for C/AArch64/AVX2, 2025. URL https://github.com/pq-code-package/mlkem-native.

J. Don, S. Fehr, C. Majenz, and C. Schaffner. Online-extractability in the quantum random-oracle model. In *EUROCRYPT 2022*, 2022. URL https://eprint.iacr.org/2021/280.

Google. Tink releases, 2026. URL https://github.com/tink-crypto/tink/releases.

Google Cloud. Post-quantum cryptography in Cloud KMS, 2026. URL https://cloud.google.com/kms/docs/post-quantum-cryptography.

P. Grubbs, J. Lu, and T. Ristenpart. Message franking via committing authenticated encryption. In *CRYPTO 2017*, 2017. URL https://eprint.iacr.org/2017/664.

Q. Guo, T. Johansson, and B.-Y. Yang. Single-trace SPA-CCA on unmasked ML-KEM on Cortex-M4. IACR ePrint 2024/2051, 2024. URL https://eprint.iacr.org/2024/2051.

V. T. Hoang and S. Tessaro. GCM-SST: AES-GCM with strong subkey-tagging. IACR ePrint 2024/875, 2024a. URL https://eprint.iacr.org/2024/875.

V. T. Hoang and S. Tessaro. Towards tight multi-user security of GCM. IACR ePrint 2024/875, 2024b. URL https://eprint.iacr.org/2024/875.

D. Hofheinz, K. Hövelmanns, and E. Kiltz. A modular analysis of the Fujisaki-Okamoto transformation. In *TCC 2017*, 2017. URL https://eprint.iacr.org/2017/604.

HQC Submission Team. HQC performance, 2025. URL https://pqc-hqc.org/doc/hqc-performance.pdf.

Intel Corporation. Data operand independent timing instructions (DOIT), 2022. URL https://www.intel.com/content/www/us/en/developer/articles/technical/software-security-guidance/best-practices/data-operand-independent-timing-isa-guidance.html.

Intel Corporation. Intel ISA-L: Intelligent storage acceleration library, 2025. URL https://github.com/intel/isa-l_crypto.

E. Kret and R. Schmidt. The PQXDH key agreement protocol, 2023. URL https://signal.org/docs/specifications/pqxdh/.

A. Langley, M. Hamburg, and S. Turner. Elliptic curves for security. RFC 7748, IETF, 2016. URL https://www.rfc-editor.org/rfc/rfc7748.

J. Len, P. Grubbs, and T. Ristenpart. Partitioning oracle attacks. USENIX Security 2021, 2021. URL https://eprint.iacr.org/2020/1153.

PQ Code Package. mlkem-native benchmarks, 2026. URL https://github.com/pq-code-package/mlkem-native#benchmarks.

PQShield. Plugging timing leaks in Kyber/ML-KEM via masking, 2024. URL https://pqshield.com/blog/power-side-channel-ml-kem.

F. Valsorda and contributors. age releases (filippo.io/age), 2025. URL https://github.com/FiloSottile/age/releases.

Y. Wang, R. Paccagnella, E. T. He, H. Shacham, C. W. Fletcher, and D. Kohlbrenner. Hertzbleed: Turning power side-channel attacks into remote timing attacks on x86. USENIX Security 2022, 2022. URL https://www.hertzbleed.com/.

C. A. Wood et al. Hybrid HPKE for post-quantum KEMs (draft-ietf-hpke-pq-09), 2026. URL https://datatracker.ietf.org/doc/draft-ietf-hpke-pq/.